

The seal of the University of Coimbra is a circular emblem. It features a central figure, likely a saint or scholar, seated and holding a book. The figure is surrounded by a decorative border containing the text 'CONIMBRIA' and 'SITATIS'. The seal is rendered in a light blue color.

Security Auditing

Lesson#5

ISO 27000: Other standards, Implementation and Certification

School Year 2025/2026

Master in Informatics Engineering (MEI)
Master in Informatics Security (MSI)

Informatics Engineering Department

University of Coimbra



Learning Objective

- Identify additional ISO 27000 series standards that address specific domains such as cloud security, privacy, energy sector security, and incident management.
- Understand how these standards build upon ISO 27001 and ISO 27002 to help organizations implement targeted security controls.



Agenda

1. Other Key ISO 27000 Series Standards
2. Implementation and Challenges
3. Audit and Compliance



Agenda

1. Other Key ISO 27000 Series Standards

1.1 ISO 27017: Cloud Security

1.2 ISO 27018: Protection of Personally Identifiable Information (PII) in Cloud Services

1.3 ISO 27019: Information Security for Energy Sector

1.4 ISO 27701: Privacy Information Management System (PIMS)

1.5 ISO 27035: Incident Management



1.1 ISO 27017: Cloud Security

- Purpose of ISO 27017

- Provides security guidelines for **cloud service providers** (CSPs) and customers. It **extends ISO 27002** by adding specific cloud-related controls to address **shared responsibility** between CSPs and customers.

- Key Security Concerns in Cloud Computing

- Data breaches and unauthorized access
- Data loss due to misconfiguration
- Insider threats within cloud service providers
- Compliance with data protection regulations (e.g., GDPR, HIPAA, PCI-DSS)

1.1 ISO 27017: Cloud Security

- Key ISO 27017 Security Controls

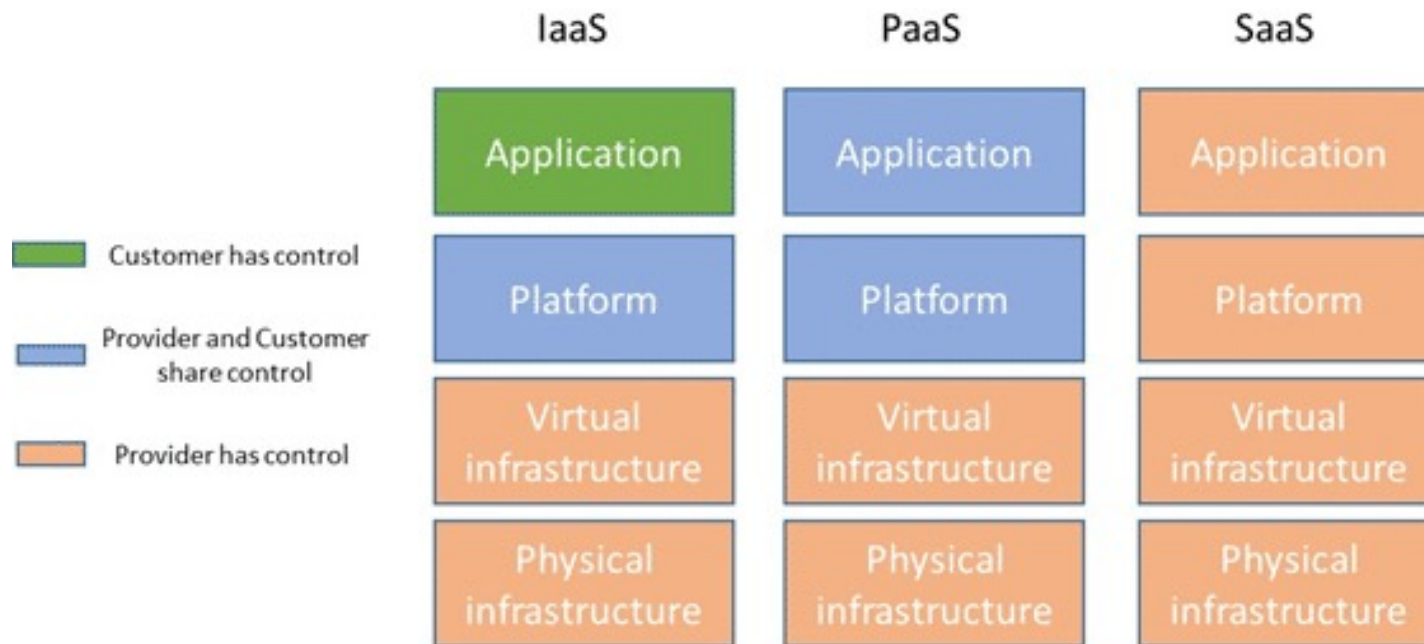


Image credits: <https://advisera.com/27001academy/blog/2016/08/23/resolving-cloud-security-concerns-by-defining-clear-responsibilities-according-to-iso-27017/>



1.1 ISO 27017: Cloud Security

- Key ISO 27017 Security Controls

- **Responsibility Matrix** – Clearly defines security responsibilities between cloud providers and customers.
- **Virtual Machine Security** – Ensures secure configuration and management of cloud instances.
- **Cloud Customer Monitoring** – Customers must implement logging and monitoring mechanisms.
- **Data Segregation & Encryption** – Prevents unauthorized access to shared cloud resources.



1.2 ISO 27018: Protection of Personally Identifiable Information (PII) in Cloud Services

- Purpose of ISO 27018

ISO 27018 focuses on protecting Personally Identifiable Information (PII) processed in cloud services. It ensures that cloud providers follow privacy best practices to safeguard customer data.

- Why is ISO 27018 Important?

- Compliance with privacy regulations (GDPR, CCPA, etc.)
- Protection against data leaks and breaches
- Establishes trust between cloud providers and customers



1.2 ISO 27018: Protection of Personally Identifiable Information (PII) in Cloud Services

- Key Privacy Principles in ISO 27018

- User Consent Management – Cloud providers must obtain explicit user consent before processing PII.
- PII Encryption & Anonymization – Reduces risks from data breaches.
- Data Residency Requirements – Ensures compliance with local regulations on where data is stored.
- Right to Erasure ("Right to Be Forgotten") – Ensures individuals can request data deletion.



1.3 ISO 27019: Information Security for Energy Sector

- Purpose of ISO 27019

- ISO 27019 provides security guidelines for critical infrastructure in the energy sector, including power grids, oil & gas, and nuclear facilities.

- Why is ISO 27019 Important?

- Energy infrastructure is a high-risk target for cyberattacks (e.g., ransomware, nation-state threats).
- It ensures secure integration of IT and operational technology (OT).
- Protects against threats like SCADA system hacking and smart grid vulnerabilities.



1.3 ISO 27019: Information Security for Energy Sector

- Key Security Controls in ISO 27019

- Physical & Logical Access Controls – Prevents unauthorized access to control systems.
- Industrial Control System (ICS) Security – Secures SCADA systems against cyber threats.
- Supply Chain Security – Ensures third-party vendors meet security requirements.
- Incident Response Plans – Defines actions for cyberattacks on energy networks.



1.4 ISO 27701: Privacy Information Management System (PIMS)

- Purpose of ISO 27701

- ISO 27701 extends ISO 27001 to cover privacy management, helping organizations comply with GDPR, CCPA, and other data protection laws. It defines how organizations should process, store, and share personal data securely.

- Who Should Implement ISO 27701?

- Companies handling large amounts of personal data (banks, healthcare, cloud providers).
- Organizations required to comply with privacy laws (GDPR, CCPA, HIPAA, etc.).



1.4 ISO 27701: Privacy Information Management System (PIMS)

- Core Components of ISO 27701

- PII Controllers vs. Processors – Defines roles in data processing.
- Privacy Impact Assessments (PIA) – Helps evaluate privacy risks before data collection.
- Data Subject Rights Management – Implements procedures for user requests (access, deletion, correction).
- Data Transfer Controls – Protects personal data when shared across borders.



1.5 ISO 27035: Incident Management

- Purpose of ISO 27035

- ISO 27035 provides a framework for **detecting, responding to, and recovering** from cybersecurity **incidents**. It ensures organizations can quickly contain and mitigate security breaches.

- Why is ISO 27035 Important?

- Reduces financial and reputational damage from cyber incidents.
- Ensures compliance with regulatory incident reporting requirements (e.g., GDPR, PCI-DSS).
- Helps organizations establish incident response teams (CSIRT/SOC).



1.5 ISO 27035: Incident Management

- Key Phases of Incident Management (ISO 27035-2)
 - Detection & Reporting – Monitor security events for anomalies.
 - Assessment & Classification – Evaluate incident severity and impact.
 - Response & Containment – Take immediate actions to minimize damage.
 - Recovery & Lessons Learned – Restore systems and improve security controls.



Agenda

2. Implementation and Challenges

2.1 Steps to Implement ISO 27001 and Related Standards

2.2 Common Pitfalls and How to Avoid Them

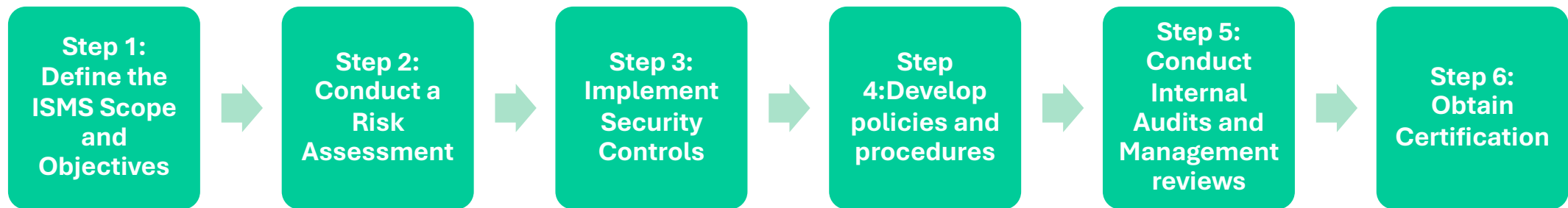
2.3 Integrating ISO 27000 Series with Other Frameworks (e.g., GDPR, NIST)

2.4 Real-World Case Studies

2.1 Steps to Implement ISO 27001 and Related Standards

Implementation Roadmap for ISO 27001

Organizations must follow a structured approach to achieve ISO 27001 certification. The key steps include:





2.1 Steps to Implement ISO 27001 and Related Standards



Step 1: Define the ISMS Scope and Objectives

- Determine **which assets, processes, and locations** the ISMS will cover.
- Align security objectives with **business goals**.
- Identify **compliance requirements** (e.g., GDPR, HIPAA).



2.1 Steps to Implement ISO 27001 and Related Standards

Step 2: Conduct a Risk Assessment (ISO 27005)

- Identify threats, vulnerabilities, and risks.
- Use a risk assessment matrix to evaluate impact and likelihood.
- Develop a Statement of Applicability (SoA) to justify selected controls.



2.1 Steps to Implement ISO 27001 and Related Standards

 **Step 3:** Implement Security Controls (ISO 27002, ISO 27017, ISO 27018, etc.)

- Establish technical, administrative, and physical controls.
- Ensure access management, encryption, network security, and incident response.
- Apply privacy-specific controls (ISO 27701) if dealing with personal data.



2.1 Steps to Implement ISO 27001 and Related Standards



Step 4: Develop Policies and Procedures

- Define policies for data classification, access control, and incident management.
- Conduct employee security awareness training.



2.1 Steps to Implement ISO 27001 and Related Standards

Step 5: Conduct Internal Audits and Management Reviews

- Regularly test ISMS effectiveness through audits.
- Engage top management in reviewing security metrics and compliance status.



2.1 Steps to Implement ISO 27001 and Related Standards



Step 6: Obtain ISO 27001 Certification

- Hire an external auditor to assess compliance.
- Address any non-conformities before certification.
- Maintain continuous monitoring and improvements.



2.2 Common Pitfalls and How to Avoid Them

Even well-prepared organizations face challenges during implementation. Some common pitfalls include:

Pitfall	Why it happens	How to avoid it
Lack of Management Support	No executive buy-in or budget constraints	Align ISMS with business objectives and show ROI.
Overcomplicating Risk Assessment	Too many details slow down implementation	Use a simplified risk assessment model to start.
Ignoring Employee Awareness	Security breaches due to untrained staff	Conduct regular training and phishing simulations.
Incomplete Documentation	Missing policies, procedures, or records	Use ISO 27001 templates to maintain compliance.
Failure to Conduct Internal Audits	Weaknesses remain undetected	Implement a continuous improvement cycle.
Not Aligning with Legal & Regulatory Requirements	Overlooking GDPR, HIPAA, or industry standards	Integrate compliance frameworks early in the process.



2.3 Integrating ISO 27000 Series with Other Frameworks

- Many organizations must comply with multiple security and privacy standards.

ISO 27000 can be integrated with:

–GDPR (General Data Protection Regulation)

- ISO 27701 (Privacy Information Management) helps implement GDPR's principles.
- Data Subject Rights Management aligns with GDPR's right to access, rectification, and deletion.
- Encryption & Anonymization fulfill GDPR's data protection requirements.

–NIST Cybersecurity Framework

- ISO 27001 and NIST CSF share a risk-based approach to security.
- ISO 27002 security controls map to NIST's Identify, Protect, Detect, Respond, Recover functions.
- Organizations can use ISO 27005 risk assessment alongside NIST's Risk Management Framework.



2.3 Integrating ISO 27000 Series with Other Frameworks

- Many organizations must comply with multiple security and privacy standards.

ISO 27000 can be integrated with:

–PCI DSS (Payment Card Industry Data Security Standard)

- ISO 27001 aligns with PCI DSS security requirements for handling payment data.
- Ensures strong access control, encryption, and network security.

–COBIT (IT Governance Framework)

- ISO 27001 complements COBIT 2019 for governance and risk management.
- COBIT focuses on decision-making & accountability, while ISO 27001 focuses on implementation.



2.3 Integrating ISO 27000 Series with Other Frameworks

- Many organizations must comply with multiple security and privacy standards.

Example Mapping:

Framework	Focus Area	ISO 27000 Alignment
GDPR	Privacy & Data Protection	ISO 27701, ISO 27018
NIST CSF	Cybersecurity Controls	ISO 27002, ISO 27005
PCI DSS	Payment Security	ISO 27001 Annex A Controls
COBIT	IT Governance	ISO 27001, Risk Management



2.4 Real-World Case Studies

Case Study 1: Successful Implementation – A Financial Institution

Challenge:

- A European bank must comply with ISO 27001, GDPR, and PCI DSS.
- The organization faced high risks from phishing attacks and third-party data breaches.



2.4 Real-World Case Studies

Case Study 1: Successful Implementation – A Financial Institution

Solution:

- Implemented ISO 27001 security policies and SOC monitoring.
- Aligned ISO 27001 with PCI DSS for payment security and ISO 27701 for privacy compliance.
- Phishing simulations helped reduce employee-driven breaches by 50%.

Key Takeaway:

- ISO 27001 can seamlessly integrate with regulatory requirements like GDPR and PCI DSS.



2.4 Real-World Case Studies

Case Study 2: Failed Implementation – A Healthcare Organization

Challenge:

- The hospital attempted to implement **ISO 27001** to secure **patient records**.
- Faced challenges due to poor documentation and lack of employee training.



2.4 Real-World Case Studies

Case Study 2: Failed Implementation – A Healthcare Organization

Failure Points:

- **No proper risk assessment**, leading to security gaps.
- Employees **ignored security policies**, causing HIPAA violations.
- Internal **audits weren't conducted**, leading to non-compliance.

Lessons Learned:

- Employee training is critical – People are the weakest link in security.
- Documentation is mandatory – Policies and risk assessments must be well-documented.
- Regular audits help maintain compliance – Annual reviews prevent security drift.



Agenda

3. Audit and Compliance

3.1 Internal vs. External Audits

3.2 Preparing for an ISO 27001 Audit

3.3 Maintaining Certification



3.1 Internal vs. External Audits

- What is an ISO 27001 Audit?

- An audit systematically evaluates an organization's ISMS (Information Security Management System) to verify compliance with ISO 27001 requirements. It ensures that security policies, procedures, and controls are adequate and continuously improving.



3.1 Internal vs. External Audits

Internal Audits (First-Party Audit)

- Conducted by internal security teams or independent internal auditors.
- Ensures the organization is ready for an external certification audit.
- Identifies non-conformities and areas for improvement before external evaluation.

–Internal Audit Steps:

- Audit Planning – Define objectives, scope, and audit schedule.
- Documentation Review – Examine policies, risk assessments, and control implementations.
- Interviews & Observations – Assess employee awareness and operational practices.
- Findings & Reporting – Document non-conformities and corrective actions.



3.1 Internal vs. External Audits

External Audits (Third-Party Certification Audit)

- Conducted by an accredited certification body (CB) (e.g., BSI, TÜV, SGS).
- Required to obtain ISO 27001 certification.
- Typically follows a 2-stage process:
 - Stage 1: Documentation Audit (Readiness Assessment)
 - Stage 2: Certification Audit



3.1 Internal vs. External Audits

External Audits (Third-Party Certification Audit)

- Stage 1: Documentation Audit ("Readiness Assessment")
 - Verifies that required policies, risk assessments, and security controls are in place.
 - Identifies gaps before the formal certification audit.
- Stage 2: Certification Audit
 - On-site assessment to verify ISO 27001 implementation.
 - Auditors test security processes, risk management, and employee awareness.
 - If successful, ISO 27001 certification is issued (valid for 3 years).



3.2 Preparing for an ISO 27001 Audit

Organizations must prepare thoroughly to pass an ISO 27001 audit. Key steps include:

Step 1: Conduct a Pre-Audit Gap Analysis

- Identify non-conformities before the official audit.
- Evaluate compliance with ISO 27001 Annex A controls.

Step 2: Ensure Documentation is Complete

- Auditors will review key ISMS documents, including:
 - Information Security Policy
 - Risk Assessment & Treatment Plan
 - Statement of Applicability (SoA)
 - Access Control & Incident Response Procedures
 - Internal Audit Reports



3.2 Preparing for an ISO 27001 Audit

Organizations must prepare thoroughly to pass an ISO 27001 audit. Key steps include:

Step 3: Train Employees on Security Policies

- Auditors interview employees to assess awareness.
- Conduct phishing tests and security drills before the audit.

Step 4: Conduct a Mock Audit

- Simulate an audit scenario with internal or third-party auditors.
- Identify gaps in policy enforcement and security controls.



3.3 Maintaining Certification

Once certified, organizations must maintain compliance through:

- Annual Surveillance Audits

- Conducted by the certification body every 12 months.
- Ensures ISMS effectiveness and continual improvement.
- Auditors check for updates to risk assessments and security controls.

- Recertification Audit (Every 3 Years)

- Full reassessment of ISO 27001 compliance.
- Required to maintain certification validity.



3.3 Maintaining Certification

Once certified, organizations must maintain compliance through:

- Continuous ISMS Improvement
 - Update risk assessments and security controls based on new threats.
 - Conduct regular training and awareness programs.
 - Review security incidents and apply corrective actions.



Summary

- ISO 27017 & ISO 27018 help secure cloud services and personal data.
- ISO 27019 strengthens security in critical infrastructure (energy sector).
- ISO 27701 provides a privacy framework for GDPR/CCPA compliance.
- ISO 27035 ensures organizations respond effectively to security incidents.
- ISO 27001 implementation requires a step-by-step approach to succeed.
- Common pitfalls (lack of management support, poor training, inadequate audits) can derail security programs.
- Integrating ISO 27001 with GDPR, NIST, and PCI DSS simplifies compliance.
- Internal audits help identify gaps before the external certification audit.
- Proper documentation, training, and risk assessments are critical for a successful audit.
- Annual surveillance audits and continuous ISMS improvements are required to maintain compliance.